

ARCHITECTURE & SECURITY REASSESSMENT

Layered Authorization Revised Findings Report

Enterprise Floor, Mission Edge

Prepared for the architecture, ICAM, security, platform, and mission teams
7 October 2026 | Review revision 2

Recommended disposition

Accept the target pattern in principle and proceed with an isolated security proof of concept.

Do not treat the revised document as evidence of production readiness. Resolve the identified design ambiguities and demonstrate enforcement before approving live access under this pattern.

Executive assessment

The 7 October revision is materially stronger than the 6 October proposal. It preserves enterprise boundaries, introduces internal enforcement, replaces the unsafe enterprise-only emergency fallback, removes mandatory post-query filtering, and qualifies standards alignment and control inheritance. These are substantive design corrections.

This reassessment identifies **14 open findings: 9 High and 5 Medium**. No Critical severity is assigned on the available design evidence. The strongest remaining concerns are ambiguous envelope fallback, potentially widening rollback, unbound decision requests, unenforced obligations, stale indexed labels, decision-to-execution races, cross-mission routing, search disclosure, and derived-artifact propagation.

What the findings mean

High: a documented ambiguity or missing contract could permit access or disclosure outside the intended effective policy. Resolve its design before live enforcement and prove the implementation.

Medium: a specification, interoperability, assurance, or governance gap needs closure before its applicable phase gate. Severity describes potential impact, not a demonstrated exploit.

Evidence and limits

Both supplied PDFs were reviewed, including the revised architecture diagrams. The prior independent assessment itself was not supplied; its recommendations are known only from the revision's statements. No source code, deployed configuration, tokens, test output, logs, control-provider package, or authorization decision was provided. Historical finding IDs and operational closure cannot be verified.

Page references use the PDFs' printed pagination. [D1] is the 32-page 6 October proposal; [D2] is the 43-page 7 October revision. [R1]-[R21] are primary standards and vendor references listed at the end. Recommendations and closure tests are reviewer judgments; they are not verbatim mandates from every cited standard.

1. Response disposition

The team's statement that findings were incorporated is supported for several design changes. The status below concerns the written architecture. Implementation effectiveness remains unverified for every row.

Issue in original proposal	Revised response / evidence	Disposition
Enterprise-only kill switch could widen access	Emergency deny, independent exceptions, and decommission conditions replace it. [D1] pp. 9, 30; [D2] pp. 14-15.	Corrected in principle; rollback/exception semantics remain open (F-02).
Gateway treated as the sole enforcement point	Ingress and internal PEPs use a common composition capability. [D1] pp. 3-4; [D2] pp. 3-8.	Corrected in principle; request binding and bypass evidence needed (F-01, F-03).
Residual filtering of mandatory collection rules	Mandatory restrictions must be enforced before results and aggregates; unsupported filters fail closed. [D1] pp. 8-9; [D2] p. 13.	Corrected in principle; Elasticsearch feature safety remains open (F-08).
Enterprise ceiling too coarse for resource controls	Envelope includes mandatory resource restrictions and exclusions. [D2] pp. 17-18.	Corrected in principle; fallback and label freshness unresolved (F-01, F-05).
Resource attributes could arrive as request metadata	Authoritative attributes and trust tiers replace caller-supplied labels. [D1] pp. 11-12; [D2] pp. 18-20.	Corrected in principle; create/update and request binding need contracts (F-03, F-06).
Loose token, delegation, and step-up descriptions	RFC profiles added; stronger authentication does not imply authorization. [D2] p. 10.	Improved, pending operational profiles and tests (F-03, F-13).
Standards and inheritance presented too strongly	Alignment is intent; inheritance requires assessment and acceptance. [D2] pp. 2, 25-26, 37.	Corrected posture; capability scope and allocation need edits (F-12, F-14).
Component/license assumptions	Tyk Operator 1.0 licensing is corrected and inventory is required. [D2] p. 35.	Supported by vendor documentation [R20-R21]; exact deployed inventory still needed.

Retain these improvements. The open findings refine the revised design; they do not require abandoning layered authorization or selecting a new authorization engine.

2. Open findings register

Proposed owners are accountable teams, not named assignees. All findings are open on this document-only evidence. F-01 through F-09 require design resolution and passing tests before live enforcement. F-10 through F-14 have the specific gates shown below.

ID / severity	Finding	Proposed owner
F-01 High	Unregistered enforcement paths retain an ambiguous fallback	Enterprise ICAM + platform team
F-02 High	A previously approved rollback can still broaden access	Engineering governance + enterprise ICAM
F-03 High	Decision requests are not yet bound to verified principals and operations	Platform team + enterprise ICAM + product teams
F-04 High	Permit obligations need mandatory enforcement semantics	Platform team + product teams + mission stewards
F-05 High	Re-indexing alone leaves a stale-label exposure path	Data platform + mission data stewards + enterprise ICAM
F-06 High	Mutable state can change between decision and execution	Product teams + platform team
F-07 High	Cross-mission routing still points to a raw decision point	Enterprise ICAM + platform team + participating missions
F-08 High	An Elasticsearch query filter does not secure every query feature	Data platform + platform authorization team
F-09 High	Derived labels need provenance and access-set composition	Mission data stewards + data/AI platform + product teams
F-10 Medium	Measurable gates and safe shadow conditions remain open	Enterprise ICAM + security engineering + platform team
F-11 Medium	Decision and audit states are not yet internally complete	Platform team + enterprise ICAM + audit function
F-12 Medium	AuthZEN scope is understated and extension contracts remain essential	Platform architecture + integration engineering
F-13 Medium	Authentication freshness and sender binding need an operational profile	Enterprise ICAM + platform security
F-14 Medium	Control inheritance still understates consumer responsibilities	ISSO + control providers + enterprise ICAM + product teams

A finding closes only when the relevant document/contract is corrected and its acceptance evidence passes. Deferral or risk acceptance must name the authorizer, scope, compensating controls, expiry, and residual risk; it is not evidence that the control is implemented.

3. Detailed findings

F-01 | HIGH

Unregistered enforcement paths retain an ambiguous fallback

Evidence: [D2] p. 18, Envelope contract: Enforcement binding

Owner: Enterprise ICAM + platform team

Observation. The envelope contract routes requests from unregistered enforcement points back to standard enterprise entitlements. This conflicts with the universal composition requirements on pp. 3-4 if the fallback can reach the same mission-protected resources without mission restrictions.

Potential impact. A caller could avoid a restrictive mission path and obtain the same object through a legacy enterprise entitlement. This is an ambiguity in the written contract; the attachments do not demonstrate an actual bypass.

Required closure. Deny access to layered mission resources from unregistered enforcement paths. Any legacy path must either apply the same required enterprise and mission controls or be an explicitly segregated resource set with a separately approved protection model. Authenticate enforcement-point identity; do not trust a supplied identifier.

Acceptance evidence. With enterprise permission and mission denial, exercise registered, unregistered, direct-service, and legacy paths. All paths to the same protected object must deny. Prove that spoofing an enforcement-point ID cannot select the envelope.

Standards basis: Complete mediation and enterprise/mission boundary integrity [R1, R2].

F-02 | HIGH

A previously approved rollback can still broaden access

Evidence: [D2] pp. 3, 15, 25, 33; administrative controls and acceptance criteria

Owner: Engineering governance + enterprise ICAM

Observation. Rollback is considered safe because it restores a previously approved policy. An older policy can be less restrictive than the active version. The objection response on p. 25 also says no administrative control widens access, although break-glass explicitly grants access.

Potential impact. Rolling back a new screening rule can restore access that is now prohibited. Previous approval is evidence of historical review, not proof that the permitted set is unchanged or safe under current attributes and envelopes.

Required closure. Treat rollback as a policy change. Permit it only after verifying current envelope compatibility and current restrictions, or retain an emergency deny until review completes. Broader access requires independent, explicit approval of its scope. Represent break-glass as a governed exception evaluated through composition, with named subject, objects/actions, reason, expiry, and non-overridable controls; never switch off a PDP.

Acceptance evidence. Deploy a policy that removes access, then request rollback to its predecessor. The operation must remain blocked or require independently approved expansion. Exercise expired, overbroad, self-approved, and enterprise-forbidden break-glass requests; each must deny.

Standards basis: Access enforcement, least privilege, change control, and audited exceptions [R6].

3. Detailed findings - continued

F-03 | HIGH

Decision requests are not yet bound to verified principals and operations

Evidence: [D2] pp. 4-10, 18-19, 29; architecture diagrams on pp. 4, 6-7

Owner: Platform team + enterprise ICAM + product teams

Observation. Tyk validates tokens and internal enforcement points call composition directly. The document does not specify who validates the end-user evidence on those direct calls, who may assert an AuthZEN subject, or how subject/actor, tenant, resource, action, and request are bound. Cerbos mappings accept role, scope, and policy-version properties.

Potential impact. Authenticated transport proves which service called; it does not prove that the supplied user or requested operation is legitimate. A forged subject, policy scope, old policy version, or action/resource mismatch could turn a valid decision into unauthorized execution.

Required closure. Authorize the PEP-to-composition API itself. Choose either verified end-user/delegated token evidence or a defined trusted PEP assertion profile. Validate its issuer, intended audience, expiry, and binding to the authenticated PEP. Derive roles, tenant, policy version, and scope server-side. Normalize resource IDs and action mapping. Bind every response/cache entry to the exact decision tuple and enforce at the resource boundary.

Acceptance evidence. Reject forged subjects/actors, cross-tenant IDs, stale policy selectors, action substitution, and replay of one resource decision against another. Prove both composition options enforce the identical identity and request-binding profile.

Standards basis: Workload identity, JWT validation, and bounded delegation [R2, R9-R12, R17].

F-04 | HIGH

Permit obligations need mandatory enforcement semantics

Evidence: [D2] pp. 5, 7-8, 17, 23, 27; glossary p. 41

Owner: Platform team + product teams + mission stewards

Observation. Composition returns obligations and applications honor them, but the report does not define their schema, mandatory versus advisory status, merge/conflict rules, or behavior when a PEP cannot carry them out. A Boolean permit is insufficient when release depends on a watermark, redaction, or destination constraint.

Potential impact. A PEP can accept both PDP permits yet release content without a required control. Conflicting obligations or partial execution can produce an effective result broader than the policy intended.

Required closure. Define a versioned obligation profile. Preserve all mandatory enterprise and mission obligations; unresolved conflicts, unknown mandatory obligations, and failed preconditions must prevent the protected action. Negotiate PEP capability against a trusted registration. Define which controls occur before execution, at commit, or as auditable post-actions. Separate the composition decision from the actual enforcement result.

Acceptance evidence. Return unknown, unsupported, conflicting, and deliberately failing mandatory obligations. No unprotected output may leave the PEP. Audit evidence must distinguish proposed permit, obligation completion/failure, and the action actually executed.

Standards basis: Controlled release and information-flow enforcement; AuthZEN context semantics [R6, R16].

3. Detailed findings - continued

F-05 | HIGH

Re-indexing alone leaves a stale-label exposure path

Evidence: [D2] pp. 13-14, 19-20; collection and revocation requirements

Owner: Data platform + mission data stewards + enterprise ICAM

Observation. Indexed security attributes are copied from resource records; reclassification triggers re-indexing and decision-cache invalidation. No barrier prevents use of an older indexed label while the index update is delayed or fails. A fresh decision-cache key cannot correct a stale searchable document.

Potential impact. After a resource becomes more restrictive, old labels can still permit hits, counts, facets, exports, or AI retrieval. Existing search snapshots and derived copies can retain the same problem.

Required closure. Define an exposure bound from authoritative change to denial at every surface. Use a restrictive-update barrier, quarantine, independently enforced exclusion, or equivalent design while propagation is incomplete. Track security-label versions and processing acknowledgments. Include replicas, collection-filter caches, search cursors/snapshots, async results, and derived stores; define recovery after missed events.

Acceptance evidence. Delay or stop indexing immediately after a restrictive label change. Exercise hits, aggregates, pagination, exports, and retrieval during the delay. Meet the approved window without disclosure after its deadline; prove recovery does not reintroduce older labels.

Standards basis: Governed resource attributes and timely authorization updates [R3, R6].

F-06 | HIGH

Mutable state can change between decision and execution

Evidence: [D2] pp. 8, 11-12, 19-20, 23; workflow and release actions

Owner: Product teams + platform team

Observation. Authoritative attributes are read before the decision, and some jobs are checked again before delivery. There is no defined atomicity contract between authorization and the database update, release, or tool action. Creation, update, and relabeling also need proposed-state validation because no authoritative new record exists yet.

Potential impact. A case can become screened, an assignment revoked, or a workflow state changed after permit but before commit. A generic preflight permit can then execute against a different resource version or an unapproved target state.

Required closure. Bind decisions to resource and relevant attribute versions. For sensitive writes, authorize the existing object and validate the proposed transition through the authoritative write path. Use conditional commit, locking, transactional enforcement, or an equivalent technique; re-evaluate on version mismatch. Define delivery-time authorization for irreversible actions and download links.

Acceptance evidence. Inject resource, entitlement, and workflow changes between evaluation and commit. The action must fail or re-evaluate under current state. Test malicious initial labels, relabeling, case reassignment, and replacement of a download target after its permit.

Standards basis: Resource-bound access enforcement and least privilege [R3, R6].

3. Detailed findings - continued

F-07 | HIGH

Cross-mission routing still points to a raw decision point

Evidence: [D2] pp. 23-24; compare universal composition on pp. 3-4

Owner: Enterprise ICAM + platform team + participating missions

Observation. Cross-mission consumers are told to ask the providing mission decision point through AuthZEN. The revised text does not explicitly route these requests through composition or identify which mission policies must participate for shared resources.

Potential impact. A raw mission permit can be mistaken for an effective permit. Selecting only one mission can omit enterprise restrictions or another resource owner's required constraints. Attribute-sharing authorization can also recurse if its own decisions require that same protected lookup.

Required closure. Expose the resource owner's governed composed endpoint to consumers. Determine applicable missions from trusted resource ownership and provenance, never caller preference. Require enterprise permission plus permission from each mission that policy declares relevant, including all obligations. Define cross-mission filter intersection and a bounded, cycle-free attribute-service bootstrap path.

Acceptance evidence. Use a resource governed by two missions: each mission must be able to cause denial independently. Direct calls to raw PDPs must not authorize resource access. Exercise unavailable providers, missing ownership, collection queries, and recursive attribute dependencies.

Standards basis: Complete mediation and preservation of all applicable restrictions [R1-R3].

F-08 | HIGH

An Elasticsearch query filter does not secure every query feature

Evidence: [D2] p. 13, search non-disclosure and data-layer backstop

Owner: Data platform + platform authorization team

Observation. The design promises totals, suggestions, similarity results, and aggregations only from the authorized set. Elastic documents that a global aggregation is independent of the query. It also documents DLS limits involving index statistics and aggregate information. Injecting a top-level query filter alone does not establish that promise.

Potential impact. A broad service credential plus an unrestricted query feature can reveal protected collection information even when returned hits are filtered. Similarity/scoring, secondary search APIs, and persisted result handles require separate verification.

Required closure. Define an allowlisted search API and permitted query AST rather than forwarding arbitrary DSL. Forbid or safely constrain global aggregations and every feature that escapes the security predicate. Test kNN/vector paths, nested/join behavior, multi-search, suggestions, and async/cursor ownership. Document residual inference limits; isolate data or suppress sensitive outputs when the mission's non-disclosure requirement cannot be met. Keep Elastic as the assessed data source.

Acceptance evidence. Query a corpus containing a known hidden document. Adversarial counts, global aggregations, suggestion/scoring, vector, and alternate-API requests must not reveal forbidden content or collection information under the approved threat model. Check role/API-key combinations and unrestricted credential paths.

Standards basis: Information-flow enforcement; documented Elasticsearch behavior [R6, R18-R19].

3. Detailed findings - continued

F-09 | HIGH

Derived labels need provenance and access-set composition

Evidence: [D2] p. 12, Derived and cached data; pp. 19, 30-31

Owner: Mission data stewards + data/AI platform + product teams

Observation. Derived artifacts inherit the most restrictive source attributes. This is a useful intent but not a complete combination rule: classification, compartments, release restrictions, mission ownership, and case predicates are not all scalar labels with a single maximum.

Potential impact. A summary, embedding, cache, or conversation can retain a restrictive classification while losing a compartment, mission screen, or source-specific condition. Later source revocation may not reach the artifact.

Required closure. Define provenance and conservative label/predicate composition. Use the intersection of source-authorized access sets unless a separately approved transformation or release process authorizes another result. Specify handling for incompatible markings and unrepresentable predicates. Propagate restrictive changes to materialized outputs and caches; define regeneration, quarantine, and retention. Isolate AI retrieval context and caches by principal and authorization context.

Acceptance evidence. Create one artifact from sources with different compartments, missions, cases, and dissemination terms. A user missing any required restriction must be denied. Reclassify or revoke a source and verify its embeddings, summaries, exports, and session/cached outputs meet the agreed propagation window.

Standards basis: Attribute governance and information-flow protection [R3, R6].

F-10 | MEDIUM

Measurable gates and safe shadow conditions remain open

Evidence: [D2] pp. 14, 32-34, 37; revocation, rollout, acceptance criteria

Owner: Enterprise ICAM + security engineering + platform team

Observation. Exposure windows remain to be set, and latency/availability/capacity/recovery objectives are not numeric. Phase 2 places independent assessment in its exit criteria. Phase 1 evaluates mission policy without enforcement but does not explicitly prohibit broader enterprise envelopes or production paths that already depend on mission protection.

Potential impact. Tests cannot give a reproducible pass/fail result without approved targets. Live enforcement or shadow activity could begin before its prerequisites are assessed, particularly if new coarse envelopes replace existing fine-grained entitlements.

Required closure. Approve a numeric target and test method for every event and service objective in Phase 0. Define event start, last unauthorized operation, clock source, peak load, partitions, and missed-event recovery. Require assessment and explicit approval before live pilot access under this pattern. Shadow mode must retain existing effective controls and must not activate envelopes that require unenforced mission restrictions.

Acceptance evidence. Provide a signed gate matrix and measured results for all event types and service objectives. Confirm with denial tests that shadow mode introduces no new effective access. Record pre-live assessment/approval and clearly distinguish pilot authorization from production authorization.

Standards basis: Risk-based assessment and authorization; continuous enforcement [R7-R8].

3. Detailed findings - continued

F-11 | MEDIUM

Decision and audit states are not yet internally complete

Evidence: [D2] pp. 7-8, 15; glossary pp. 39-40

Owner: Platform team + enterprise ICAM + audit function

Observation. The truth table includes mission Not applicable but the four-state audit enum excludes it; enterprise Not applicable is absent. The table does not cover malformed, incomplete, or per-item batch responses. Composition is described as recording the outcome actually enforced before the PEP executes it.

Potential impact. Adapters can collapse coverage gaps into ordinary denials or inconsistently interpret missing batch items. Logging an intended permit as an executed action overstates enforcement evidence and can conceal obligation failures.

Required closure. Define normalized states and reason codes for coverage gaps, invalid responses, timeouts, and skipped evaluation. An enterprise coverage gap must deny. Either add a distinct gap state or consistently map it to deny with a coverage-gap reason. Correlate each batch item to its tuple and require execute-all behavior when needed. Join the composition record to a separate PEP enforcement/obligation outcome; specify safe durable logging behavior during audit outages.

Acceptance evidence. Run a complete state matrix for single and batch requests, including short/invalid responses and reordered items. Verify no missing evaluation permits access and that the audit trail distinguishes evaluated, skipped, failed, permitted, denied, and actually executed operations.

Standards basis: Access-decision and audit controls; AuthZEN Boolean response [R6, R16].

F-12 | MEDIUM

AuthZEN scope is understated and extension contracts remain essential

Evidence: [D2] pp. 2, 5, 35, 39; sources p. 38

Owner: Platform architecture + integration engineering

Observation. The revision and glossary describe AuthZEN as decision and batch-decision APIs. The final 1.0 specification also defines subject, resource, and action search APIs. Those enumerate authorized entities; they do not define a Cerbos PlanResources AST or Elasticsearch filter translation. Cerbos documents partial AuthZEN support.

Potential impact. Treating the standard as either decision-only or a portable filter API creates false interoperability expectations. Vendor-specific properties, policy outputs, and filter operators remain integration dependencies.

Required closure. Correct the standards description and publish a supported-capabilities matrix for the pinned enterprise PDP, Cerbos, gateway plugin, and composition API. Keep native query planning and filter translation in a versioned extension. Define obligation semantics and normalized error handling explicitly; AuthZEN can carry them in response context without standardizing their meaning. Pin implementation versions, schemas, operators, and adapter tests.

Acceptance evidence. Demonstrate supported single/batch endpoints and discovery against pinned builds. Identify unsupported search capabilities explicitly. Verify custom filter/obligation contracts survive an adapter or PDP substitution without weakening enforcement.

Standards basis: AuthZEN 1.0 sections 5.5, 6-9; Cerbos API documentation [R16-R17].

3. Detailed findings - continued

F-13 | MEDIUM

Authentication freshness and sender binding need an operational profile

Evidence: [D2] pp. 10, 29-30, 35, 37; glossary p. 42

Owner: Enterprise ICAM + platform security

Observation. The added RFC profiles are appropriate, but acr/amr/freshness claims and proof-of-possession checks are still co-design items. RFC 9068 makes auth_time, acr, and amr optional; token issuance time alone is not the user's authentication time. mTLS transport alone is not a certificate-bound access token.

Potential impact. A newly exchanged token could incorrectly appear to satisfy fresh authentication. TLS termination or actor changes can break sender binding. The glossary's absolute stolen-token replay protection claim omits compromised keys and implementation failures.

Required closure. Require verifiable authentication evidence where policy depends on it, preserve authentication time through refresh/exchange, and define maximum-age evaluation and clock skew. Separate AAL from federation assurance. Define RFC 9470 HTTP challenge handling and safe retry/idempotency behavior. For mTLS tokens verify the certificate confirmation; for DPoP validate request/token binding, proof age, replay policy, and required nonce behavior at each hop. Define workload-only identities independently of interactive MFA.

Acceptance evidence. Reject missing/unknown assurance evidence and stale authentication even with a fresh access token. Test wrong certificates, substituted keys, replayed proofs, and trusted-proxy metadata spoofing. Demonstrate step-up re-evaluation and that denied write retries do not execute twice.

Standards basis: Digital identity, access tokens, step-up, and proof of possession [R4-R5, R9, R13-R15].

F-14 | MEDIUM

Control inheritance still understates consumer responsibilities

Evidence: [D2] pp. 25-31; ownership/RACI pp. 19-23

Owner: ISSO + control providers + enterprise ICAM + product teams

Observation. The report correctly makes inheritance conditional, but some candidate-common rows have explicit consumer obligations: AC-3(8), AC-3(13), AU-2/AU-12, IA-9, and IA-11. Their allocation needs component-level evidence. Many product-side obligations cannot be satisfied solely by a common provider.

Potential impact. A product team could assume a control is fully inherited while session interruption, resource labels, log emission, workload validation, or step-up handling is incomplete. The markings RACI also needs confirmation by the actual security/marketing authority rather than an assumed ICAM mandate.

Required closure. Split provider and consumer implementations or mark them hybrid where appropriate; fully inherited status is possible only for the scope demonstrably supplied by the provider. Record boundary, implementation statement, parameters, evidence, assessor, and consumer duties. Pin the adopted control-catalog release and tailoring. Confirm marking authority and delegate vocabulary administration explicitly. Map NIST logical policy-engine, policy-administrator, and enforcement functions without requiring a separate appliance for each.

Acceptance evidence. Produce an accepted provider/consumer responsibility matrix and evidence package for the selected baseline. Walk representative product paths to verify consumer controls. Obtain the applicable authority's acceptance; a control crosswalk alone cannot close the finding.

Standards basis: Selected 800-53 controls, assessment procedures, and RMF boundaries [R6-R8].

4. Standards and architecture assessment

The revised design is compatible in principle with externalized, layered ABAC. Neither NIST ZTA nor ABAC requires a particular vendor, two PDPs, enterprise-first evaluation, or AuthZEN. Those are valid local design choices when their effective controls preserve policy. A two-permit rule alone does not establish Zero Trust.

Reference	Assessment	Evidence still needed
NIST SP 800-207 / 207A [R1-R2]	Improved resource and workload enforcement coverage. Composition is a logical authorization function; identify policy-engine and policy-administrator functions, including interruption.	PEP inventory, protected control-plane paths, workload trust, revocation, posture inputs, non-bypassability, and negative tests. F-01, F-03, F-07, F-10.
NIST SP 800-162 [R3]	Appropriate ABAC direction with authoritative subject/resource attributes and governed vocabulary.	Trustworthy binding, create/update state validation, index freshness, cross-mission provenance, and equivalent collection enforcement. F-03, F-05-F-09.
NIST SP 800-63B-4 / 63C-4 [R4-R5]	The added digital-identity reference is useful but cannot establish assurance from a generic MFA or acr claim. AAL and federation assurance are distinct.	Verified assurance mapping, phishing-resistant authentication where applicable, authentication freshness, federation/session behavior. F-13.
OAuth / JWT [R9-R15]	RFC 9068, 8725, 9700, 8693, 9470, 8705, and 9449 are appropriate profile references. The revised token-exchange wording correctly separates mechanism from delegation semantics.	Issuer/audience/token-type validation, actor authority, claim provenance, sender proof, proxy boundaries, and safe step-up retry. F-03, F-13.
OpenID AuthZEN 1.0 [R16]	Final standard covers single evaluations, batch evaluations, search APIs, and discovery. Context can carry obligations; their semantics are implementation-defined.	Supported-capability matrix, versioned extensions, per-item batch behavior, authoritative inputs, and obligation enforcement. F-04, F-11-F-12.
NIST SP 800-53 / 53A / 37 [R6-R8]	Control mapping is preliminary and authorization appropriately deferred. Catalog mapping is not control effectiveness or an ATO.	Selected baseline/tailoring, provider and consumer implementation evidence, assessor results, residual risks, and authorizer acceptance. F-10, F-14.
Elastic / Cerbos / Tyk [R17-R21]	Cerbos query planning and Tyk extensibility support a viable POC, but the custom composition/filter integration remains unproven.	Pinned builds, supported operators, security/licensing inventory, search safety, negative tests, and upgrade regression evidence. F-08, F-12.

Applicability must be established by the organization's security authority. This review does not determine the system's classification, NSS status, selected control baseline, agency-specific overlays, cross-domain approval, or authorization boundary.

5. Phase gates and closure evidence

Gate	Required evidence / decision
Before POC/shadow execution	Approved envelope, identity/decision-binding model, preliminary threat model, test corpus, safe shadow boundary, and numeric revocation/performance targets. Shadow must retain existing effective access controls. Synthetic or otherwise properly authorized test data must be used.
Before composition option selection	Both options tested against the same state machine, binding rules, batch behavior, obligations, filter contracts, audit model, failure tests, and workload assumptions. Select on measured security and operations evidence; the document alone does not establish that either option is superior.
Before live pilot access	Resolve F-01-F-09; complete the applicable F-10-F-14 prerequisites. Independent assessment and explicit scoped pilot approval precede live use. Have exercised emergency deny, safe rollback, break-glass expiry, dependency failures, and recovery.
Before production authorization	Complete all relevant closure tests; verify the selected control baseline and provider/consumer obligations; document residual risks and performance/resilience evidence; obtain the applicable authorization. Do not convert pilot approval into a general production approval.

Minimum evidence package

Evidence artifact	Required contents
Enforcement inventory	Resource boundaries and operation/action map covering ingress, east-west service calls, data access, workers, events, AI tools, exports, and management paths; owner and authenticated PEP identity for each.
Executable security tests	Test ID, finding ID, negative/positive input, expected result, actual result, pinned component/policy/attribute versions, audit correlation, pass/fail, and reviewer. Include adversarial collection behavior and concurrent-state changes.
Revocation results	For each event: numeric approved window, source event timestamp, delivery/invalidation acknowledgments, last forbidden operation, worst-case measurement, fault/load conditions, missed-event recovery, and derived-store coverage.
Operations and assurance	Latency and throughput under peak load; availability and recovery objectives; failure-injection results; key/policy rollout and rollback; component inventory; control statements and assessment evidence.

Suggested tracking fields: Finding ID, assigned owner, corrective contract/change, test IDs, target gate, evidence link, reviewer, disposition, and approval/expiry where applicable. Retest after a relevant policy, gateway/plugin, adapter, datastore, or identity-profile change.

6. Priority document edits

The following replacement language is proposed for team review. It preserves the revised pattern while removing ambiguities; implementation contracts and passing tests remain necessary.

Envelope enforcement binding - replace p. 18 fallback

"The envelope is valid only through authenticated, registered enforcement points. Requests from other paths to layered mission resources are denied. An alternative path may access those resources only when it demonstrably enforces all applicable enterprise and mission restrictions under the same approved protection model."

Rollback and exceptions - clarify pp. 15 and 25

"Rollback is subject to current envelope and restriction validation. A previously approved version is not automatically safe to restore. Any expansion of effective access requires independent authorization of its scope, duration, and non-overridable controls. Break-glass is an explicit policy exception evaluated through composition, not a bypass of required enforcement."

Cross-mission decisions - replace pp. 23-24 routing

"A consumer requesting access to another mission's resources calls that resource owner's governed composition endpoint. Composition determines every applicable mission from trusted resource metadata and provenance and requires enterprise permission plus all required mission permissions and obligations."

AuthZEN scope - correct pp. 2 and 39

"AuthZEN Authorization API 1.0 defines single and batch evaluations, authorized subject/resource/action search APIs, and discovery. Native policy query plans and datastore filter translation are separate contracts. Response context may convey obligations and step-up information; this design defines their interoperable semantics and mandatory enforcement behavior."

Permit and audit contract - clarify pp. 8 and 15

"A protected action executes only after valid enterprise and all required mission permits are bound to that action and all mandatory pre-execution obligations are satisfied. Composition records its decision; the PEP separately records the actual enforcement and obligation outcome under the same decision and correlation identifiers."

Live rollout gate - update pp. 33-34

"Before live pilot access, independent assessment and scoped approval are complete, security prerequisites pass, and numeric revocation and operations targets are met. Shadow mode preserves existing effective controls and does not activate new envelopes whose safety depends on unenforced mission restrictions."

Secondary cleanup

Describe applications as containing enforcement integration but no independently authored authorization policy. Qualify token replay protection as protection against use without the bound key and successful proof validation. Confirm that the RACI's enterprise marking authority is actually delegated to ICAM. Preserve the corrected Tyk Operator licensing statement and inventory exact deployed components.

7. References

[D1] Layered Authorization: Enterprise Floor, Mission Edge. 6 October 2026. Supplied PDF, 32 pages.

[D2] Layered Authorization: Enterprise Floor, Mission Edge. 7 October 2026. Supplied revised PDF (filename suffix "(1)"), 43 pages.

Primary sources below were checked for this reassessment on 7 October 2026 (America/New_York). Vendor documentation is version-sensitive; acceptance testing must use pinned deployed versions. URLs are clickable.

[R1] NIST SP 800-207, Zero Trust Architecture

Sections 2.1, 3, 3.4, and 5; August 2020.

<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-207.pdf>

[R2] NIST SP 800-207A, cloud-native access control

Final publication; September 2023.

<https://csrc.nist.gov/pubs/sp/800/207/a/final>

[R3] NIST SP 800-162, ABAC definition and considerations

Attribute, policy, and enforcement architecture.

<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-162.pdf>

[R4] NIST SP 800-63B-4, Authentication and Authenticator Management

Authentication assurance, phishing resistance, and sessions.

<https://pages.nist.gov/800-63-4/sp800-63b.html>

[R5] NIST SP 800-63C-4, Federation and Assertions

Federation assurance and assertion protection.

<https://pages.nist.gov/800-63-4/sp800-63c.html>

[R6] NIST SP 800-53 Rev. 5, control catalog

AC-3, AC-4, AC-6, AC-16, AC-24, AC-25; AU, CM, and IA families as selected. Publication page also identifies Release 5.2.0.

<https://csrc.nist.gov/pubs/sp/800/53/r5/upd1/final>

[R7] NIST SP 800-53A Rev. 5, control assessment

Assessment procedures and evidence planning.

<https://csrc.nist.gov/pubs/sp/800/53/a/r5/final>

[R8] NIST SP 800-37 Rev. 2, Risk Management Framework

Control allocation, assessment, authorization, and monitoring.

<https://csrc.nist.gov/pubs/sp/800/37/r2/final>

[R9] RFC 9068, JWT Profile for OAuth 2.0 Access Tokens

Sections 2.2, 2.2.1, and 4.

<https://www.rfc-editor.org/rfc/rfc9068.html>

[R10] RFC 8725, JSON Web Token Best Current Practices

Sections 3.1 and 3.8-3.12.

<https://www.rfc-editor.org/rfc/rfc8725.html>

[R11] RFC 9700, OAuth 2.0 Security Best Current Practice

OAuth security and token protection.

<https://www.rfc-editor.org/rfc/rfc9700.html>

7. References - continued

[R12] RFC 8693, OAuth 2.0 Token Exchange

Sections 1.1, 2, and 4.1.

<https://www.rfc-editor.org/rfc/rfc8693.html>

[R13] RFC 9470, Step Up Authentication Challenge Protocol

Sections 3-5.

<https://www.rfc-editor.org/rfc/rfc9470.html>

[R14] RFC 8705, mTLS and certificate-bound access tokens

Sections 3 and 6.5.

<https://www.rfc-editor.org/rfc/rfc8705.html>

[R15] RFC 9449, Demonstrating Proof of Possession (DPoP)

Sections 4.3, 7, and 8-9.

<https://www.rfc-editor.org/rfc/rfc9449.html>

[R16] OpenID Authorization API 1.0 (AuthZEN)

Sections 5.5 and 6-10; final specification.

https://openid.net/specs/authorization-api-1_0.html

[R17] Cerbos PDP API documentation

AuthZEN mappings, partial implementation, and PlanResources query plans. Version pinning required.

<https://docs.cerbos.dev/cerbos/latest/api/>

[R18] Elastic security limitations

Document-level security, global statistics, aggregate information, aliases, and persisted result access.

<https://www.elastic.co/docs/deploy-manage/security/limitations>

[R19] Elastic global aggregation reference

Global aggregation is independent of the search query.

<https://www.elastic.co/docs/reference/aggregations/search-aggregations-bucket-global-aggregation>

[R20] Tyk Operator 1.0 release notes

Closed-source and license requirement.

<https://tyk.io/docs/5.6/product-stack/tyk-operator/release-notes/operator-1.0/>

[R21] Tyk Gateway repository

License boundary: MPL 2.0 outside the ee directory; inventory deployment components.

<https://github.com/TykTechnologies/tyk>

Review conclusion: retain the revised layered pattern, resolve its remaining security contracts, and use the integrated proof of concept to produce reviewable enforcement evidence. Production readiness remains undemonstrated.